

СИСТЕМА АВТОМАТИЧЕСКОЙ БЕСШОВНОЙ РОТАЦИИ КРИПТОГРАФИЧЕСКИХ КЛЮЧЕЙ АВТОРИЗАЦИИ В ВЫСОКОНАГРУЖЕННОЙ МИКРОСЕРВИСНОЙ ПЛАТФОРМЕ

Микросервисная архитектура позволяет независимо разворачивать компоненты системы, однако вместе с ростом числа сервисов расширяется и поверхность атаки [1]. Для межсервисной авторизации широко применяются JWT-токены [2], слабым местом которых является приватный ключ подписи: его компрометация дает злоумышленнику возможность создавать произвольные токены и получать неограниченный доступ ко всем ресурсам платформы [3]. Данная проблема обостряется, когда единый закрытый ключ разделяется между всеми микросервисами: компрометация любого из них равносильна компрометации всей системы авторизации. Именно такая ситуация сложилась в платформе Mindbox [4] — экосистеме роста бизнеса, насчитывающей порядка 120 микросервисов, развернутых в нескольких кластерах Kubernetes. Единый RSA-ключ хранился в HashiCorp Vault и был доступен каждому сервису, а ротация ключа требовала одновременного обновления всех контуров развёртывания, что на практике делало её невозможной.

Цель работы — проектирование, реализация и внедрение системы автоматической бесшовной ротации криптографических ключей в высоконагруженной микросервисной платформе.

Для достижения цели необходимо решение следующих *задач*:

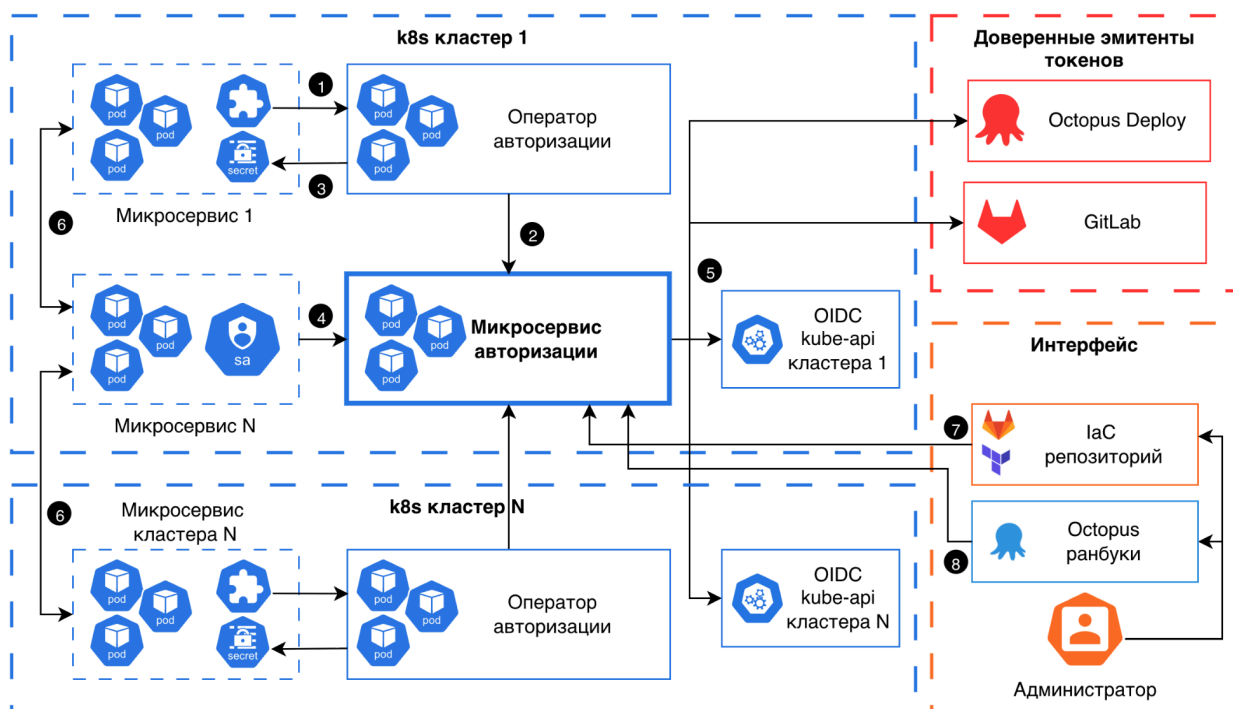
1. Анализ текущей системы межсервисной авторизации и выявление её ограничений.
2. Исследование существующих решений для бесшовной ротации криптографических ключей.
3. Проектирование архитектуры системы ротации с учетом особенностей платформы.
4. Разработка и тестирование компонентов системы.
5. Перевод микросервисов платформы на новую систему авторизации.
6. Апробация системы: запуск автоматической ротации ключей по расписанию.

В основу решения положена архитектура с централизованным микросервисом авторизации — единственным компонентом, имеющим доступ к приватному ключу подписи. Бесшовная ротация стала возможной благодаря двум ключевым механизмам. Во-первых, в каждом Kubernetes-кластере развернут оператор авторизации — контроллер, который раз в 30 секунд читает спецификацию запрашиваемых токенов из Custom Resource, получает токены и публичные ключи у микросервиса авторизации и записывает их в секреты Kubernetes. Таким образом, при ротации ключа обновлённые данные доставляются ко всем микросервисам автоматически через push-механизм оператора, без необходимости перезапуска подов. Во-вторых, реализован grace-период: после смены ключа подписи все микросервисы платформы, продолжают принимать токены, подписанные предыдущим ключом, в течение заданного интервала. Это гарантирует, что уже выпущенные токены остаются валидными на время распространения нового ключа по всем кластерам.

Архитектура решения представлена на рис. 1. Для федерации кластеров микросервис авторизации получает публичные ключи через OIDC-интерфейс kube-api каждого кластера и самостоятельно валидирует SA-токены микросервисов [5]. Конфигурация клиентов и политик управляется декларативно через IaC-репозиторий, а интеграция с внешними эмитентами (Ocorpus Deploy, GitLab) реализована через Token Exchange.

Система успешно апробирована в промышленной эксплуатации платформы Mindbox, обрабатывающей свыше 2 миллионов запросов в минуту. Ключи ротируются автоматически по расписанию без прерывания работы сервисов при сохранении SLA на генерацию токена — не более 30 мс по 95 перцентилю. Доступ к приватному ключу подписи ограничен

единственным микросервисом авторизации, что закрывает критическую уязвимость прежней схемы, при которой ключ был доступен всем 120 сервисам.



- ❶ Оператор раз в 30 секунд читает CR – спецификацию запрашиваемых токенов из микросервиса авторизации.
- ❷ Оператор на основе спецификации получает токены и публичные ключи у микросервиса авторизации.
- ❸ Оператор записывает полученные данные авторизации в секрет микросервиса.
- ❹ Микросервис получает токены от сервиса авторизации, если данные известны только в рантайме. Авторизация через SA токен.
- ❺ Для авторизации субъектов и возможностей федерации сервис авторизации запрашивает публ. ключи доверенных систем.
- ❻ Микросервисы отправляют и авторизуют запросы с помощью полученных данных. В том числе, между разными кластерами.
- ❼ Администратор управляет конфигурацией микросервиса авторизации (клиенты, политики, эмитенты) через IaC репозиторий.
- ❽ Octopus ранбуки дают доступ к ручному администрированию: принудительный запуск ротации, выпуск токенов для отладки.

Рисунок 1 – Архитектура решения

Таким образом, разработана и внедрена система автоматической бесшовной ротации криптографических ключей, обеспечивающая непрерывность обработки запросов и существенно повышающая безопасность межсервисной авторизации в высоконагруженной микросервисной платформе.

ЛИТЕРАТУРА

1. Research Trends and Recommendations for Future Microservices Research / Z. Stojanov [и др.] // Trudy ISP RAN/Proc. ISP RAS. — 2024. — Т. 36, № 1. — С. 105—130. — DOI 10.15514/ISPRAS-2024-36(1)-7.
2. Jones M., Bradley J., Sakimura N. JSON Web Token (JWT): RFC / Internet Engineering Task Force (IETF). — 2015. — № 7519. — URL: <https://www.rfc-editor.org/rfc/rfc7519.html>.
3. Enhancing Microservices Security with Token-Based Access Control Method / A. Venčkauskas [и др.] // Sensors. — 2023. — Т. 23, № 6. — С. 3363. — DOI 10.3390/s23063363.
4. ООО «Майндбокс». Mindbox — экосистема роста бизнеса. — URL: <https://mindbox.ru/> (дата обращения: 15.03.2026).
5. OpenID Foundation. OpenID Connect Core 1.0. — 2014. — URL: https://openid.net/specs/openid-connect-core-1_0.html (дата обращения: 15.03.2026).